

# Stoquify Agent Alert Evidence Capture Runbook

---

**Date:** 2026-07-25

**Scope:** Agent Runtime Phase 2A operational release evidence

**Activation authority:** None

**Phase 3 authority:** None

## Purpose

This runbook defines the provider-neutral contract for collecting production-like alert evidence without copying secrets, raw webhook bodies, authorization headers, tenant data, or mutable screenshots into the release register.

The collector proves that:

- invalid authentication is rejected;
- the authorized evidence endpoint is available over query-free HTTPS;
- the alert transport is healthy;
- delivery has an external request identity;
- a real security incident owner acknowledged within the declared SLO;
- retry, dead-letter, protected recovery, backup escalation, and alert-secret rotation have evidence references;
- the captured evidence is recent, sanitized, and SHA-256 bound;
- only the `alerting` section of the operational register can be changed.

The collector cannot change release identity, CI evidence, approvals, owners, scheduler evidence, credential-rotation evidence, declared status, or activation fields.

## Required Configuration

Configure these values through the deployment secret and configuration systems. Do not place real values in source control.

```
STOQUIFY_AGENT_ALERT_EVIDENCE_URL=https://<evidence-host>/<path>
STOQUIFY_AGENT_ALERT_EVIDENCE_SECRET=<managed-secret-minimum-32-characters>
STOQUIFY_AGENT_RELEASE_ENVIRONMENT=internal_pilot
STOQUIFY_AGENT_ALERT_EVIDENCE_TIMEOUT_MS=20000
```

The evidence URL must:

- use HTTPS outside local development;
- contain no username, password, query string, or fragment;
- expose `GET` with bearer authentication;
- return `401` for an invalid bearer value;
- return the sanitized response contract below for the authorized request.

# Evidence Endpoint Contract

```
{
  "ok": true,
  "data": {
    "ready": true,
    "environment": "internal_pilot",
    "transportStatus": "HEALTHY",
    "transportReference": "alert-transport://internal-pilot/webhook",
    "managedSecretReference": "secret-manager://alerts/current",
    "httpsDeliveryReference": "evidence://alerts/https-delivery/<id>",
    "externalRequestReference": "external-request://alerts/<id>",
    "deliveredAt": "2026-07-25T12:00:00.000Z",
    "acknowledgementSloMinutes": 15,
    "acknowledgedAt": "2026-07-25T12:05:00.000Z",
    "acknowledgedByDirectoryId": "directory://person/<security-owner>",
    "acknowledgementReference": "evidence://alerts/acknowledgement/<id>",
    "retryEvidenceReference": "evidence://alerts/retry/<id>",
    "deadLetterEvidenceReference": "evidence://alerts/dead-letter/<id>",
    "recoveryEvidenceReference": "evidence://alerts/recovery/<id>",
    "escalationTestedAt": "2026-07-25T12:10:00.000Z",
    "escalatedToDirectoryId": "directory://person/<on-call-owner>",
    "escalationEvidenceReference": "evidence://alerts/escalation/<id>",
    "secretRotationEvidenceReference": "evidence://alerts/secret-rotation/<id>"
  }
}
```

All references must be value-free URI-style identifiers. Query-bearing or fragment-bearing references, synthetic identities containing `e2e`, `test`, `seed`, `fixture`, or `demo`, malformed timestamps, and unknown fields are rejected or discarded.

## Capture Procedure

1. Deploy the alert receiver and evidence endpoint in the same production-like pilot environment.
2. Store the webhook and evidence-endpoint secrets in the managed secret system.
3. Generate a real alert delivery and retain the external request identifier.
4. Have the named security incident owner acknowledge it within the configured SLO.
5. Prove one retry and one terminal dead-letter transition.
6. Recover the dead-letter through the protected recovery path.
7. Prove escalation to the named on-call backup owner.
8. Rotate the alert transport secret and prove new-version success plus old-version rejection.
9. Expose only the sanitized response contract.
10. Run the report command:

```
npm run agent:alert:evidence:report
```

11. Inspect the JSON and Markdown evidence under `what-next/agents-runtime/`.
12. Apply a ready capture atomically:

```
npm run agent:alert:evidence:apply
```

13. Re-run the release evidence gate:

## Fail-Closed Rules

The collector refuses to update the operational register when:

- the evidence endpoint is absent, non-HTTPS, query-bearing, unavailable, oversized, or malformed;
- invalid authentication is not rejected with `401` ;
- the source reports a different environment;
- any required value-free reference is invalid;
- the delivery is older than 24 hours or has a future timestamp;
- acknowledgement is missing, precedes delivery, or exceeds the SLO;
- escalation is missing, precedes delivery, or has a future timestamp;
- the acknowledger is not the register's primary `SECURITY_INCIDENT` owner;
- the escalation target is not the register's primary `ON_CALL_BACKUP` owner;
- the register has any requested, authorized, or completed activation value.

## Retained Evidence

The collector retains:

- sanitized timestamps, references, owner directory identifiers, and SLO;
- invalid-auth and environment-match outcomes;
- a SHA-256 hash of the sanitized capture;
- a bounded human-readable report.

It does not retain:

- bearer values;
- authorization headers;
- raw HTTP bodies;
- webhook request bodies;
- secret values;
- database URLs;
- environment snapshots;
- tenant or business records.

## Current Preflight

The repository preflight was executed without managed external configuration and correctly returned:

```
{
  "ok": false,
  "code": "ALERT_EVIDENCE_URL_MISSING",
  "secretValuesPrinted": false
}
```

No external evidence was fabricated and no operational register field was updated.